

T09 — Finding

One per finding. Attached to or embedded in the engagement report.

RT-[ENGAGEMENT]-[NNN] — [TITLE]

The title states the defect and not the achievement. “Service account passwords are recoverable from directory data”, not “administrative control of the domain was obtained”.

Field	Value
Finding ID	RT-[ENGAGEMENT]-[NNN]
Severity	☐ Critical ☐ High ☐ Medium ☐ Low ☐ Informational
Category	☐ Prevention ☐ Detection ☐ Response ☐ Recovery ☐ Process
Threat level at which this is reachable	☐ 1 ☐ 2 ☐ 3 ☐ 4
ATT&CK technique(s)	
Threat-profile action / flow IDs	
Status	☐ Open ☐ Remediated — awaiting retest ☐ Closed (retest passed) ☐ Risk accepted

1. Affected assets

Type	Identifier	Owner

2. Description

What the weakness is. Plain language. No blame.

Response / notes

3. How it was exploited

The technique and the procedure — enough that a defender can reproduce the behaviour and build a detection for it.

Response / notes

Steps:

#	Reproduction step
1	
2	
3	

4. Evidence

Evidence ID	Description	Original / working-copy reference	Integrity verified
			☐
			☐

Screenshots redacted, timestamps visible.

5. Mission / business impact

The field that determines whether this gets fixed. State what this enables an adversary to do that matters to the organisation — not what it enables technically.

Response / notes

Response / notes

Impact dimension	Assessment
Confidentiality	
Integrity	
Availability	
Mission / service affected	
Regulatory or legal consequence	

6. Root cause

Not a restated symptom. “Weak password policy” is a symptom. “Service accounts have no assigned owner, so no compensating control was ever applied to them” is a root cause. Fixing symptoms produces the same finding next year.

Field	Value
Root cause	
Cause type	☐ Configuration ☐ Design ☐ Process ☐ Resourcing ☐ Awareness ☐ Ownership gap
Why it went unnoticed	
Possible prior finding reference	
Comparison basis: control objective, environment and attack condition	
Recurrence conclusion	☐ Validated recurrence ☐ Not recurrence ☐ Not comparable ☐ Prior correction not exercised

7. Recommendation

Primary recommendation:

Response / notes

Alternatives, if the primary is not feasible:

Option	Effect	Effort	Trade-off
--------	--------	--------	-----------

Quick win available before full remediation?

Response / notes

8. Detection opportunity

Mandatory where the finding cannot be prevented economically. It provides the defensive element with an available action while the structural correction is scheduled.

Field	Value
-------	-------

Observable behaviour

Data source required

Does that telemetry exist today?	☐ Yes ☐ Partial ☐ No
----------------------------------	---

Suggested detection logic

Expected false positive profile

Detection built during this engagement?	☐ Yes — ref: ☐ No
---	---

9. Ownership and remediation

Field	Value
Owner (role, not individual)	
Accepted by owner	☐ Yes — date: ☐ Disputed — see § 11
Target date	
Remediation approach agreed	
Dependencies	
Read-across: comparable services, systems, identities or suppliers	
Read-across owner and completion evidence	

10. Retest

Field	Value
Retest method (<i>the exact method of verification</i>)	
Retest requested by owner on	
Retest performed on	
Retest performed by	
Environment, action IDs and evidence references	
Conditions changed since original test	
Result	☐ Passed — finding closed ☐ Failed — finding remains open ☐ Partially remediated
Note	

A finding is closed by a passed retest and not by the closure of a task.

11. Dispute / risk acceptance

If severity is disputed:

Field	Value
Red team assessment	
Assessed organisation's assessment	
Basis stated by the assessed organisation	
Resolution	

If the organisation elects not to remediate:

Field	Value
Risk accepted	☐ Yes
Rationale	
Compensating controls in place	

Accepted by (Approving Authority)

Date

Review date

Acceptance of risk is a legitimate decision. It is not closure. The finding remains open and is reviewed on the date above.